COMPTE RENDU DE TRAVAUX PRATIQUES

Sujet : Déploiement et Configuration d'un IDS/IPS (Suricata sur pfSense)

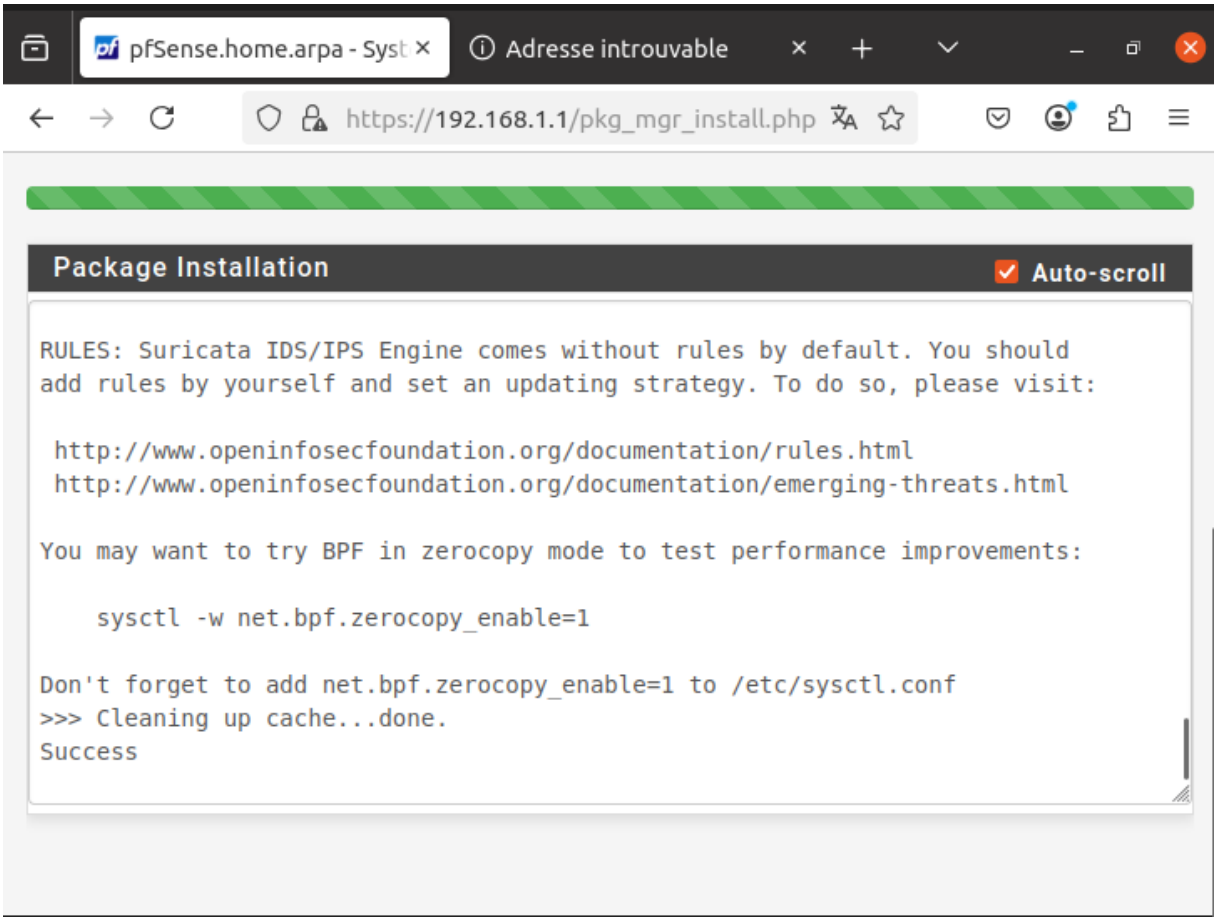
Objectif : Mise en place d'une défense active pour détecter et bloquer les scans réseaux et les tentatives d'exploitation de vulnérabilités.

---

1. Introduction et Architecture du Laboratoire

L'objectif de ce TP est de passer d'un pare-feu statique (filtrage de ports) à un système d'analyse intelligente de paquets. L'architecture utilisée est la suivante :

- **Pare-feu :** pfSense avec le paquet Suricata installé.
- **Attaquant :** Kali Linux (positionné sur le segment WAN ou LAN selon le test).
- **Cibles :** Machines Ubuntu et Windows (réseau LAN 192.168.1.0/24).
- **Sonde :** Suricata configuré sur l'interface **em1 (LAN)**.



https://192.168.1.1/suricata/suricata_int

General Settings

Enable

☑ Checking this box enables Suricata inspection on the interface.

Interface

LAN (em1)

Choose which interface this Suricata instance applies to. In most cases, you will want to choose LAN here if this is the first Suricata-configured interface.

Description

LAN

Enter a meaningful description here for your reference. The default is the pfSense interface friendly description.

Logging Settings

Send Alerts to System Log

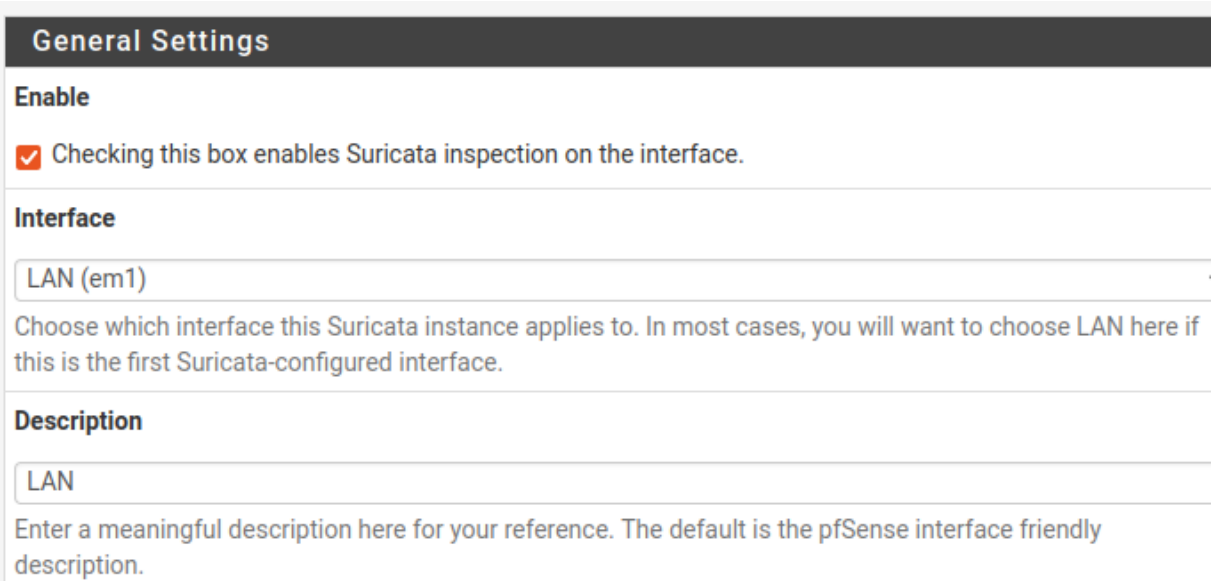
☐ Suricata will send Alerts from this interface to the firewall's system log.

NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.

2. Installation et Configuration de Suricata

2.1. Activation de l'interface

Comme le montre la **capture** , Suricata a été activé sur l'interface **LAN**. C'est un choix stratégique : cela permet de surveiller le trafic "Est-Ouest" (mouvements latéraux entre machines internes) et de détecter précisément quelle machine interne est visée



2.2. Gestion des Signatures (Règles)

Le moteur Suricata ne peut rien détecter sans une base de connaissances. Nous avons configuré les **Emerging Threats Open Rules**.

- **Rôle des signatures :** Elles contiennent les "empreintes" numériques des attaques connues.
- **Mise à jour :** Une vérification du journal système a été nécessaire pour valider le téléchargement des règles, garantissant que la sonde dispose des patterns les plus récents.

INSTALLED RULE SET MD5 SIGNATURES

Rule Set Name/Publisher	MD5 Signature Hash	MD5 Signature Date
Emerging Threats Open Rules	1e6411974127dda731fa4df4c046ff1e	Tuesday, 28-Apr-26 12:51:41 WA
Snort Subscriber Rules	Not Enabled	Not Enabled
Snort GPLv2 Community Rules	Not Enabled	Not Enabled
Feodo Tracker Botnet C2 IP Rules	Not Enabled	Not Enabled
ABUSE.ch SSL Blacklist Rules	Not Enabled	Not Enabled

UPDATE YOUR RULE SET

Last Update: Apr-28 2026 12:51
Result: success

Update Force

3. Tests d'Attaque et Détection (Mode IDS)

3.1. Reconnaissance avec Nmap

Une tentative de scan furtif a été réalisée depuis Kali : `sudo nmap -sS 192.168.1.10`

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS 192.168.1.10
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 08:17 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0050s latency).
Not shown: 996 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
53/tcp open  domain
80/tcp open  http
MAC Address: 08:00:27:F2:5F:28 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.54 seconds
```

- **Résultat de l'attaquant :** Nmap a identifié les ports 21 (FTP), 22 (SSH), 53 (DNS) et 80 (HTTP).
- **Résultat de l'IDS :** L'onglet **Alerts** a immédiatement généré des logs. montrant une détection de priorité 1 (Potential Corporate Privacy Violation), prouvant que l'IDS analyse le trafic en temps réel.

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GI
04/28/2026 14:11:43	⚠	1	UDP	Potential Corporate Privacy Violation	192.168.1.100	68	192.168.1.1	67	1:

lert Entries. (Most recent entries are listed first)

Class	Src	SPort	Dst	DPort	GID:SID	Description
Potential Corporate Privacy Violation	192.168.1.100	68	192.168.1.1	67	1:2022973	ET INFO Possible Kali Linux hostname in DHCP Request Packet

3.2. Tentative d'exploitation SMB

À l'aide de **Metasploit** (`msfconsole`), une tentative d'exploitation sur le protocole SMB (port 445) a été initiée. Contrairement à un simple scan, cette attaque tente d'injecter du code malveillant. L'IDS a pu identifier cette activité grâce aux signatures spécifiques aux vulnérabilités.

```
       =[ metasploit v6.4.18-dev                          ]
+ -- --=[ 2437 exploits - 1255 auxiliary - 429 post       ]
+ -- --=[ 1471 payloads - 47 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.1.10:         - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >
```

4. Passage au mode IPS (Prévention)

Initialement, Suricata était en mode **Disabled** pour le blocage (voir **capture 7**). Pour sécuriser réellement le réseau, nous avons activé le mode **IPS** :

- **Configuration :** Activation de "Block Offenders" en mode **Legacy**.
- **Conséquence :** Dès que Kali lance un scan ou une exploitation, Suricata ordonne au pare-feu de bannir l'IP de Kali.
- **Validation :** Après activation, le scan Nmap échoue ou est fortement perturbé, et l'attaquant perd tout accès à la cible.

Alert and Block Settings

Block Offenders

☑ Checking this option will automatically block hosts that generate a Suricata alert.

IPS Mode

Legacy Mode

Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Suricata inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode.

Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Suricata can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers include: bnxt, cc, cxgbe, cxl, em, ena, ice, igb, igc, ix, ixgbe, ixl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.

Kill States

☑ Checking this option will kill firewall states for the blocked IP. Default is Checked.

Suricata

Interfaces | Global Settings | Updates | Alerts | Blocks | Files | Pass Lists | Suppress | Logs View

Logs Mgmt | SID Mgmt | Sync | IP Lists

Interface Settings Overview

	Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
☐	LAN (em1)		AUTO	LEGACY MODE	LAN	

+ Add Delete

5. Analyse Conceptuelle

5.1. Différence entre IDS et IPS

- **IDS (Détection) :** Agit comme une caméra de surveillance. Il voit l'attaque, génère une alerte, mais laisse l'attaquant agir.
- **IPS (Prévention) :** Agit comme un garde du corps. Il voit l'attaque et coupe immédiatement la connexion pour protéger la cible.

5.2. L'importance du filtrage des alertes

Avec des milliers de règles activées (comme vu en **capture 12**), il est crucial de savoir filtrer les alertes par niveau de sévérité (Priorité 1, 2 ou 3) pour ne pas être submergé par les faux positifs et se concentrer sur les menaces critiques.

6. Conclusion

Ce TP a permis de démontrer qu'un pare-feu seul est insuffisant face à des flux autorisés (comme HTTP ou SMB) utilisés à des fins malveillantes. L'ajout de **Suricata** apporte une couche d'intelligence indispensable. Nous avons désormais les compétences pour :

- Surveiller un réseau en temps réel.
- Identifier des comportements anormaux.
- Réagir automatiquement face à une intrusion.